PORTAFOLIO DE EVIDENCIAS

NOMBRE DEL ESTUDIANTE	Valencia Hernandez Carlos Eduardo
MATRICULA	04220057
CARRERA	Ingeniería en sistemas computacionales
CORREO ELECTRONICO	choterifa@gmail.com
ASIGNATURA	Pentesting
SEMESTRE	9°
DOCENTE	Dr. Holzen A. Martínez García
CORREO ELECTRONICO	hmartinez@itsprogreso.edu.mx holzen.mg@progreso.tecnm.mx

Tabla de contenido

Reglas de comportamiento 4
Evaluación diagnostica 4
Parcial 1 Unidad 1: Introducción al pentesting 6
1. Introducción 9
2. Aspecto teórico: fundamentos del pentesting 10
2.1 Definición clara de pentesting 10
2.2 Objetivos y alcances 10
2.3 Metodologías reconocidas 11
3. Aspecto histórico: evolución del pentesting 12
3.1 Orígenes del pentesting 12
3.2 Evolución de técnicas y herramientas 13
3.3 Relación con casos reales 14
4. Aspecto reflexivo: análisis crítico 15
4.1 Casos exitosos analizados 15
4.2 Casos fallidos analizados 16
4.3 Reflexión sobre lecciones aprendidas 17
4.4 Propuestas de buenas prácticas 17
5. Conclusiones 19
6. Referencias 20
1. Introducción 28
2. Alcance del Pentesting 30
Objetivo general 30
Objetivos específicos 30
Objetivos (Target URLs y Endpoints) 30
Roles para probar 31
Áreas excluidas (Out-of-Scope) 32
Áreas de prueba según OWASP Top 10 y OWASP API Security Top 10 33
Arsenal de herramientas y justificación técnica 33
3. Tipos de prueba 35



Análisis comparativo de los tres enfoques (Caja Negra, Blanca y Gris) 35
Justificación de la selección: Caja Gris (Grey Box) 36
4. Ventana de Usuario y Consideraciones Temporales 37
Concepto teórico de la ventana de usuario en ciberseguridad 37
Política de Congelamiento de Cambios (Change Freeze) 38
Canales de comunicación y contacto de emergencia 38
5. Roles y Responsabilidades 39
Estructura de gobernanza y actores del proyecto 39
Matriz RACI del proyecto de pentesting 40
6. Reglas de Operación (RoE) 41
Lineamientos y reglas de compromiso continuo 42
7. Conclusiones y Reflexiones del Equipo 44
Coevaluación final (parcial 1) 47
Autoevaluación final (parcial 1) 48
Experiencias de aprendizaje y comentarios finales (parcial 1) 49

Reglas de comportamiento

Reglas de comportamiento del grupo

DERECHOS DEL ALUMNO:

1. Ser respetado por el maestro y el alumno
2. Participar libremente durante las clases
3. Recibir asesorías en caso de no haber comprendido un tema, o aclarar dudas, dicha asesoría se deberá solicitar con un día de anticipación.
4. Recibir retroalimentación en el momento que decida hacerlo
5. Que se le justifique la inasistencia, siempre y cuando presente la evidencia que justifique la falta.
6. Se le reciban, revisen y regresen los trabajos, proyectos de evaluación, prácticas, tareas y actividades evaluadas.
7. Recibir sus promedios de evaluaciones o después de ser evaluado.

OBLIGACIONES:

1. Respetar a su maestro y a sus compañeros
2. Asistir puntualmente a sus clases programadas.
3. Mantener disciplina en las clases y exposiciones del maestro
4. No ingerir alimentos dentro del aula y horarios de clases
5. Mantener limpio y ordenado el salón de clases
6. Cumplir con actividades, tareas, proyectos, investigaciones individuales y en equipo que se le asignen
7. Evitar el uso de celular o aparatos electrónicos que alteren el orden y disciplina en las clases.
8. Integrar y reportar al maestro cada vez que lo requiera el portafolio de evidencias del módulo, el cual incluya trabajos, tareas, actividades, proyectos, que evidencien las competencias generadas en el desarrollo del módulo.

Dr. Holzen A. Martínez-García
NOMBRE Y FIRMA DEL DOCENTE

NOMBRE Y FIRMA DEL ESTUDIANTE



Instituto Tecnológico Superior Progreso
Dirección General
Subdirección académica



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



Instituto Tecnológico Superior Progreso
Dirección General
Subdirección académica

Parcial 1

Unidad 1: Introducción al pentesting



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx

1- Informe teórico-histórico-reflexivo acerca del pentesting

Informe teórico-histórico-reflexivo acerca del pentesting.

Cierre: domingo, 6 de septiembre de 2026, 00:00

Elabora un informe que abarcque la historia, teoría y reflexión acerca del pentesting, tomando como base los casos discutidos en sesión.

Rúbrica:

1. Aspecto teórico (fundamentos) – 20 pts

- Definición clara de Pentesting (5 pts)
- Objetivos y alcances (5 pts)
- Metodologías reconocidas (10 pts)

2. Aspecto histórico (evolución) – 20 pts

- Orígenes del Pentesting (5 pts)
- Evolución de técnicas y herramientas (5 pts)
- Relación con casos reales (10 pts)

3. Aspecto reflexivo (análisis crítico) – 30 pts

- Casos exitosos analizados (5 pts)
- Casos fallidos analizados (5 pts)
- Reflexión sobre lecciones aprendidas (10 pts)
- Propuestas de buenas prácticas (10 pts)

4. Estructura del informe – 15 pts

- Introducción clara (3 pts)
- Desarrollo organizado (4 pts)
- Conclusiones pertinentes (4 pts)
- Bibliografía confiable (4 pts)

Evidencia:

Instituto Tecnológico Superior Progreso

Tarea:
Informe teórico-histórico-reflexivo acerca del pentesting.

Fecha de entrega:
6 de septiembre de 2026

Asignatura:
Pentesting

Docente:
Martínez García Holzen Atocha

Alumno:
Valencia Hernández Carlos Eduardo

Carrera:
Ingeniería en sistemas computacionales

Semestre/Grupo:
Noveno/Grupo 1

1. Introducción

Hoy en día, la seguridad informática es uno de los temas más críticos para cualquier empresa o institución. Con la llegada de los servicios en la nube, el trabajo remoto y las aplicaciones web modernas, las redes corporativas ya no están protegidas por un simple perímetro físico. Al mismo tiempo, los ataques cibernéticos se han vuelto mucho más frecuentes y sofisticados: desde grupos organizados que buscan dinero mediante ransomware hasta actores avanzados que intentan robar información confidencial o sabotear operaciones.

Durante mucho tiempo, la respuesta tradicional de las organizaciones fue adoptar una postura netamente defensiva y reactiva: instalar antivirus, colocar cortafuegos (firewalls) y esperar que las alertas avisaran cuando algo saliera mal. Sin embargo, los constantes incidentes de seguridad que vemos en las noticias demuestran que esta estrategia es insuficiente. El defensor tiene que proteger miles de puertos, servidores y usuarios, mientras que al atacante le basta con encontrar un solo error o una mala configuración para comprometer toda la red.

Frente a esta realidad surge la necesidad de la seguridad ofensiva y, de manera concreta, del pentesting o pruebas de penetración. La idea central es muy simple pero contundente: la mejor forma de saber si un sistema es seguro es intentar vulnerarlo de forma autorizada y controlada, pensando y actuando exactamente como lo haría un atacante real antes de que un criminal lo haga.

El objetivo de este informe es analizar a fondo el pentesting desde tres ángulos clave: su fundamentación teórica y metodológica, su evolución histórica y su relación con casos reales de la industria, y finalmente una reflexión crítica sobre los éxitos, fracasos y lecciones que nos dejan estos ejercicios en el mundo real. Con esto se busca entender no solo las herramientas técnicas, sino también el valor estratégico, los límites operativos y las buenas prácticas que deben seguirse para que estas pruebas realmente mejoren la seguridad de los sistemas.

2. Aspecto teórico: fundamentos del pentesting

2.1 Definición clara de pentesting

El test de penetración (pentesting) es un método de evaluación de seguridad en el cual un profesional o equipo especializado simula un ataque real contra una infraestructura tecnológica, red o aplicación, bajo autorización previa y por escrito. Su meta fundamental no es únicamente encontrar fallos teóricos en el software, sino intentar explotarlos de manera controlada para verificar hasta dónde podría llegar un atacante y qué impacto real tendría esa intrusión en la organización.

En la práctica y en los cursos de seguridad, suele existir confusión entre tres actividades que parecen similares pero tienen enfoques y alcances muy distintos:

- **Escaneo de vulnerabilidades:** Es un proceso casi 100% automatizado mediante software (como Nessus u OpenVAS) que rastrea puertos y servicios para detectar fallos conocidos en bases de datos (firmas). Aunque es rápido, genera muchos falsos positivos y no prueba si una falla realmente se puede explotar en el entorno real.
- **Auditoría de cumplimiento:** Es una revisión de tipo administrativo y documental para comprobar si una empresa cumple con normas o leyes específicas (como ISO 27001, PCI-DSS para tarjetas de crédito o GDPR). Funciona como una lista de verificación (checklist) donde se certifica que existen ciertas políticas, pero no se prueba la resistencia técnica real del sistema.
- **Pentesting (prueba de penetración):** Es un ejercicio práctico, manual y analítico. El especialista utiliza herramientas pero sobre todo su propio razonamiento para encadenar fallos menores (exploit chaining), evadir defensas, escalar privilegios en los servidores y demostrar con pruebas fehacientes qué datos o sistemas quedaron expuestos, descartando por completo los falsos positivos.

2.2 Objetivos y alcances

Los objetivos principales de un pentesting son: identificar las vías de acceso que un atacante podría aprovechar, cuantificar el impacto operacional o económico que causaría una intrusión, evaluar la efectividad real de las defensas y de los equipos de monitoreo (Blue Team), y entregar a la dirección técnica recomendaciones claras para solucionar los problemas detectados.

Dependiendo del nivel de información previa que la empresa evaluada entregue a los analistas, el pentesting se clasifica en tres modalidades reconocidas:

- **Caja negra (Black Box):** Los analistas no reciben ninguna información técnica interna, solo el nombre de la empresa o dominios públicos. Simula el punto de vista de un atacante externo desconocido. Requiere una fase muy intensa de recolección de información (OSINT) y escaneo inicial.
- **Caja blanca (White Box):** El equipo de pruebas recibe información completa: diagramas de arquitectura de red, código fuente, documentación de APIs e incluso credenciales con distintos niveles de privilegio. Es ideal cuando se desea una revisión profunda y exhaustiva del sistema.
- **Caja gris (Grey Box):** Es el esquema más habitual en las empresas. Se entrega un acceso limitado, como una cuenta de usuario estándar y nociones básicas de la red. Simula el escenario sumamente común de un empleado interno descontento o de un atacante que ya consiguió engañar a un usuario mediante phishing y busca moverse por la red interna.

Un componente indispensable en cualquier prueba son las **Reglas de Compromiso (Rules of Engagement o RoE)**. Este es el contrato formal y legal que delimita exactamente qué se puede y qué no se puede hacer durante la prueba. En las RoE se definen las direcciones IP autorizadas, los servidores excluidos (para no afectar la operación diaria o servidores de cobro), los horarios permitidos para las pruebas, y los protocolos de aviso inmediato si se descubre una vulnerabilidad extremadamente grave. Sin este documento firmado por la autoridad competente, cualquier intento de intrusión constituye un delito informático.

2.3 Metodologías reconocidas

Para que un pentesting sea profesional, ordenado y repetible, no se trabaja de forma improvisada, sino siguiendo metodologías estándar reconocidas por la industria de ciberseguridad:

- **PTES (Penetration Testing Execution Standard):** Es una de las metodologías más completas del ámbito profesional. Define siete etapas sucesivas: 1) Acuerdos iniciales (Pre-engagement), 2) Recolección de información (Intelligence Gathering), 3) Modelado de amenazas (Threat

Modeling), 4) Análisis de vulnerabilidades, 5) Explotación, 6) Post-explotación (donde se mide el valor de los datos comprometidos y persistencia), y 7) Elaboración del reporte técnico y ejecutivo.

- **NIST SP 800-115:** Desarrollada por el Instituto Nacional de Estándares y Tecnología de EE. UU. Es la guía de referencia técnica para entidades de gobierno y organizaciones que manejan infraestructuras críticas. Organiza las pruebas en cuatro grandes fases: Planificación, Descubrimiento, Ataque y Reporte.
- **OSSTMM (Open Source Security Testing Methodology Manual):** Diseñada por ISECOM, aporta un enfoque científico y métrico. Se enfoca en cuantificar la seguridad operacional calculando Valores de Evaluación de Riesgo (RAV) y analizando cómo interactúan las personas, la infraestructura tecnológica y la seguridad física.
- **OWASP WSTG (Web Security Testing Guide v4.2):** Es el estándar indiscutible para auditar aplicaciones y servicios web. Contiene guías paso a paso organizadas en 12 categorías para probar la autenticación, autorización, gestión de sesiones, validación de datos de entrada, criptografía y errores en la lógica de negocio de las páginas y APIs.

3. Aspecto histórico: evolución del pentesting

3.1 Orígenes del pentesting

El origen del pentesting se remonta a la década de 1960, cuando la expansión de los sistemas de tiempo compartido (time-sharing) hizo evidente que varios usuarios podían acceder simultáneamente a un mismo computador, lo que abrió interrogantes sobre la confidencialidad de la información. En 1967, durante la Joint Computer Conference, especialistas en seguridad debatieron por primera vez de forma pública la necesidad de "penetrar" deliberadamente los sistemas para descubrir sus debilidades antes de que lo hiciera un tercero no autorizado.

A partir de esa discusión, el Departamento de Defensa de los Estados Unidos, la Fuerza Aérea, la NSA y la RAND Corporation impulsaron la creación de los llamados "tiger teams": grupos formados por especialistas que intentaban comprometer sistemas gubernamentales y militares bajo autorización explícita. Paralelamente, en 1970, Willis H. Ware coordinó para la RAND Corporation el informe

Security Controls for Computer Systems, donde se alertó formalmente sobre la fragilidad de los enlaces remotos. En 1971 la Fuerza Aérea de EE. UU. ordenó pruebas de seguridad sobre sistemas de tiempo compartido, y en 1974 se realizó una de las evaluaciones más citadas de esta etapa: la prueba de penetración al sistema operativo MULTICS, que reveló fallas críticas de seguridad y sirvió de base para investigaciones posteriores sobre arquitecturas de referencia seguras.

Un hito fundamental ocurrió en 1972, cuando James P. Anderson publicó un reporte técnico que proporcionó lineamientos paso a paso para los Tiger Teams, estableciendo las bases metodológicas del pentesting moderno. Los pasos formalizados por Anderson fueron:

1. Encontrar una vulnerabilidad explotable.
2. Diseñar un ataque alrededor de ella.
3. Probar el ataque en un entorno controlado.
4. Aprovechar una línea en uso para operaciones ACS (acceso al canal del sistema).
5. Introducir el ataque en el objetivo.
6. Explotar la entrada para la recuperación o modificación de información clasificada.

Poco después, en 1973, el Departamento de Defensa formalizó la primera metodología de prueba denominada FMH (Flaw Hypothesis Methodology), estructurando el proceso de plantear hipótesis sobre fallos lógicos, verificarlos de forma activa y documentar el impacto para su corrección.

3.2 Evolución de técnicas y herramientas

Durante los años 80 y 90, con la masificación de las redes corporativas e Internet, el pentesting pasó de ser una práctica exclusivamente militar a una necesidad del sector privado. Es en esta etapa cuando el término "hacking ético" comienza a popularizarse para distinguir la actividad autorizada de la intrusión maliciosa. En sus comienzos, las pruebas requerían técnicas manuales de phreaking y war dialing mediante software como ToneLoc para discar miles de teléfonos buscando módems corporativos desprotegidos, además de scripts en C y Perl desarrollados de forma artesanal.

Hacia finales de los 90, las técnicas manuales dieron paso a herramientas especializadas: SATAN (1995) fue el primer escáner que generó debate público sobre la detección remota; Nmap (creado en 1997 por

Fyodor) revolucionó el escaneo de puertos y el reconocimiento de sistemas operativos, y Nessus (1998) automatizó el rastreo de vulnerabilidades en servicios de red.

A mediados de los 2000 surgieron frameworks integrales como Metasploit (2003), que unificó la explotación de vulnerabilidades conocidas en una plataforma modular y extensible, cambiando para siempre el trabajo de los analistas. En el ámbito de las aplicaciones web, la aparición de Burp Suite y OWASP ZAP facilitó la interceptación y manipulación de tráfico HTTP, mientras que la publicación periódica del OWASP Top 10 (desde 2003) estandarizó el lenguaje sobre los riesgos más comunes en el software.

En la década de 2010, la sofisticación de las amenazas avanzadas persistentes (APT) impulsó la aparición de plataformas de simulación de adversarios como Cobalt Strike, Mythic o Sliver, orientadas no solo a encontrar vulnerabilidades técnicas aisladas sino a emular cadenas completas de ataque (kill chain), incluyendo movimientos laterales y persistencia silenciosa. Más recientemente, la disciplina ha incorporado automatización basada en inteligencia artificial para priorizar hallazgos y correlacionar información de reconocimiento a gran escala (OSINT), a la par del auge del pentesting como servicio (PTaaS) y de los programas de recompensas por vulnerabilidades (Bug Bounty), que amplían la superficie de escrutinio con comunidades globales de investigadores.

3.3 Relación con casos reales

La evolución del pentesting no puede desligarse de los incidentes reales que han demostrado, en la práctica, tanto el valor de las pruebas de penetración como las graves consecuencias de omitirlas o aplicarlas de forma superficial:

- **Brecha de Target (2013):** Atacantes ingresaron a la red corporativa a través de credenciales robadas a un proveedor de climatización (Fazio Mechanical) que tenía acceso remoto. Debido a una deficiente segmentación de red interna, los atacantes se movieron lateralmente hasta alcanzar los terminales punto de venta (POS) y robar datos de más de 40 millones de tarjetas de pago. Este caso evidenció la importancia de evaluar la seguridad de terceros dentro del alcance de cualquier pentest.
- **Brecha de Equifax (2017):** La explotación de una vulnerabilidad conocida en Apache Struts (CVE-2017-5638), para la cual ya existía parche oficial disponible meses antes, expuso datos personales

y financieros de 147 millones de personas. El caso ilustra que detectar una falla técnica o recibir un reporte no basta si la organización no tiene un proceso ágil para gestionar su remediación.

- **Brecha de Capital One (2019):** Una atacante explotó una mala configuración en un firewall de aplicación web (WAF) alojado en Amazon Web Services (AWS) mediante una vulnerabilidad SSRF (Server-Side Request Forgery). A través de esto accedió a los metadatos de la nube y robó datos de más de 100 millones de clientes, mostrando los riesgos específicos de las arquitecturas cloud y la necesidad de auditar permisos IAM.
- **Brecha de Uber (2022):** Un atacante obtuvo acceso a los sistemas internos de la empresa mediante técnicas de ingeniería social y fatiga de autenticación multifactor (MFA fatigue) dirigida a un empleado externo contratista. Una vez dentro de la intranet, encontró credenciales administrativas en scripts compartidos. Esto demostró que las pruebas de penetración deben incorporar de forma sistemática vectores humanos y no limitarse a lo puramente tecnológico.
- **Colonial Pipeline (2021):** El compromiso de una contraseña filtrada de una cuenta de VPN que no tenía autenticación multifactor provocó la paralización del mayor gasoducto de combustibles de la costa este de EE. UU., subrayando la enorme relevancia del pentesting en sectores de infraestructura crítica.
- **Caso SolarWinds (2020):** La inserción de código malicioso en las actualizaciones oficiales de la plataforma Orion demostró el peligro de los ataques a la cadena de suministro de software (SUNBURST), dejando claro que los pentests modernos deben auditar también los pipelines de desarrollo e integración continua (CI/CD).

4. Aspecto reflexivo: análisis crítico

4.1 Casos exitosos analizados

Entre los ejemplos que demuestran el valor del pentesting bien ejecutado se encuentran los programas de Bug Bounty de compañías como Google, Microsoft o el propio Departamento de Defensa de EE. UU. (con iniciativas como 'Hack the Pentagon'). En estos esquemas, investigadores externos identifican y

reportan de forma responsable fallos críticos antes de que puedan ser explotados maliciosamente, permitiendo a los equipos de desarrollo corregirlos oportunamente.

De igual manera, los ejercicios de Red Teaming en el sector bancario alineados a marcos como TIBER-EU han demostrado una alta efectividad para exponer brechas en la capacidad de detección y respuesta de los equipos internos. Al simular atacantes reales, estos ejercicios suelen descubrir configuraciones erróneas críticas en Active Directory (como delegaciones Kerberos indebidas o elevación de privilegios locales) que los escáneres automáticos pasan por alto por completo.

El éxito de estos casos tiene en común un único elemento esencial: la madurez en el proceso organizacional. Esto implica contar con un alcance bien definido, un seguimiento formal de los hallazgos, la asignación de responsables técnicos para la remediación y la repetición periódica de las pruebas para verificar que las brechas fueron efectivamente solucionadas.

4.2 Casos fallidos analizados

En contraste, casos como el de Equifax muestran que la existencia de hallazgos de seguridad no garantiza protección si la organización carece de un proceso eficaz de gestión de parches e inventario de activos. La empresa realizaba auditorías periódicas, pero el reporte técnico quedó archivado sin aplicarse en los servidores productivos correctos.

De forma análoga, incidentes como el de Uber en 2022 o su fuga de datos de 2016 (donde credenciales de AWS estaban expuestas en repositorios privados de GitHub) evidenciaron que muchas organizaciones concentran sus pruebas exclusivamente en la infraestructura perimetral oficial y descuidan el factor humano y los entornos de desarrollo, a pesar de que la ingeniería social continúa siendo el vector de compromiso inicial más efectivo.

Asimismo, en el plano operativo se han documentado casos donde pruebas de penetración mal planificadas o sin reglas de compromiso claras causaron la caída involuntaria de servidores de producción o el bloqueo de autómatas programables (PLCs) en redes industriales y sistemas SCADA, demostrando que un pentest sin la debida calibración puede causar el mismo daño que intenta prevenir.

4.3 Reflexión sobre lecciones aprendidas

Al investigar los casos exitosos y fallidos se desprenden lecciones muy concretas sobre las limitaciones del modelo tradicional de seguridad:

- **El pentesting es una fotografía puntual:** Representa el estado de seguridad en una fecha y hora específicas. En empresas modernas que actualizan código y despliegan servicios varias veces por semana, el valor de un informe anual se diluye con rapidez si no se complementa con evaluaciones continuas.
- **La trampa del cumplimiento de papel:** Realizar pruebas únicamente para obtener un sello de certificación reglamentario genera una falsa sensación de seguridad. Las organizaciones suelen limitar artificialmente el alcance de la prueba para 'aprobar la auditoría', dejando fuera los sistemas más expuestos.
- **La remediación es tan importante como la detección:** Descubrir cien fallas no mejora la seguridad de la empresa si el equipo técnico no cuenta con el tiempo, los recursos o el conocimiento necesario para solucionarlas. Un pentesting exitoso termina con los parches aplicados, no con la entrega del documento PDF.
- **El factor humano no se puede omitir:** Ningún firewall o sistema de cifrado detiene a un atacante que engaña a un empleado mediante vishing o fatiga de notificaciones push. La seguridad técnica debe complementarse siempre con programas de concientización y pruebas controladas de ingeniería social.

4.4 Propuestas de buenas prácticas

Para superar estas deficiencias y lograr que las pruebas ofensivas aporten valor real, se proponen las siguientes buenas prácticas para las organizaciones actuales:

- **Adoptar ejercicios de Purple Teaming:** Fomentar que el equipo ofensivo (Red Team) y el defensivo (Blue Team) trabajen juntos en tiempo real durante la prueba. Esto permite a los defensores ajustar sus reglas en el SIEM o antivirus inmediatamente después de que un ataque es probado.

- **Integración continua en DevSecOps (Shift-Left):** Incorporar pruebas automatizadas de código (SAST y DAST) en las fases iniciales del ciclo de desarrollo. Esto soluciona los errores básicos de forma temprana y permite que los analistas humanos se concentren en buscar fallas complejas de lógica en el pentest final.
- **Enfoque de pruebas guiadas por inteligencia de amenazas (TLPT):** Diseñar los ejercicios ofensivos basándose en amenazas reales documentadas que atacan específicamente al sector de la empresa, como lo exige el marco TIBER-EU para instituciones bancarias.
- **Gestión de vulnerabilidades por riesgo real (RBVM):** Priorizar la solución de fallas considerando la probabilidad de explotación real (métricas como EPSS y el catálogo de exploits conocidos de CISA) en lugar de guiarse únicamente por el puntaje numérico del CVSS.
- **Definición exhaustiva de Reglas de Compromiso (RoE):** Establecer límites claros, contactos de emergencia y salvaguardas operativas para proteger la estabilidad de los servicios en producción.

5. Conclusiones

A través de este informe se ha examinado cómo el pentesting ha dejado de ser una actividad puramente experimental de laboratorios militares para convertirse en un componente indispensable de la ingeniería de sistemas moderna. La historia de los primeros Tiger Teams en los años 70 y la evolución de herramientas como Nmap, Metasploit y las modernas plataformas de emulación de adversarios muestran que la disciplina ha evolucionado al mismo ritmo acelerado que la tecnología y los métodos de los atacantes.

Sin embargo, la principal conclusión que se extrae de los incidentes reales analizados es que la efectividad del pentesting no depende de la sofisticación de las herramientas empleadas, sino de la madurez operativa de la organización. Casos como Target, Equifax o Uber confirman que una prueba técnica aislada no previene incidentes si no existe un compromiso real para corregir los hallazgos, si se excluyen partes críticas de la infraestructura o si se ignora el comportamiento humano.

En definitiva, el pentesting no debe verse como un trámite para aprobar una auditoría, sino como un proceso de aprendizaje continuo. Cuando se combina con enfoques colaborativos como Purple Teaming y se integra en el desarrollo ágil mediante DevSecOps, el hacking ético se convierte en la mejor herramienta con la que cuentan los profesionales de sistemas para anticiparse a los incidentes y construir sistemas verdaderamente confiables y resilientes.

6. Referencias

Anderson, J. P. (1972). *Computer security technology planning study* (Technical Report ESD-TR-73-51, Vol. I & II). Electronic Systems Division, Air Force Systems Command, United States Air Force. https://apps.dtic.mil/sti/citations/AD0758206

Herzog, P. (2010). *OSSTMM 3: The Open Source Security Testing Methodology Manual*. Institute for Security and Open Methodologies (ISECOM). https://www.isecom.org/OSSTMM.3.pdf

McGraw, G. (2006). *Software security: Building security in*. Addison-Wesley Professional.

MITRE Corporation. (2023). *MITRE ATT&CK® Enterprise Matrix (v13)*. https://attack.mitre.org/

OWASP Foundation. (2020). *Web Security Testing Guide (WSTG) - Version 4.2*. Open Web Application Security Project. https://owasp.org/www-project-web-security-testing-guide/

Penetration Testing Execution Standard Team. (2014). *The Penetration Testing Execution Standard (PTES)*. http://www.pentest-standard.org/

Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). *Technical guide to information security testing and assessment* (NIST Special Publication 800-115). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-115

Schneier, B. (2000). *Secrets and lies: Digital security in a networked world*. John Wiley & Sons.

Ware, W. H. (1970). *Security controls for computer systems: Report of Defense Science Board Task Force on Computer Security* (Report R-609-1). RAND Corporation. https://www.rand.org/pubs/reports/R609-1.html

2- Presentación individual acerca de los fundamentos del pentesting

Presentación individual acerca de los fundamentos del pentesting.

Cierre: martes, 8 de septiembre de 2026, 00:00

Instrucciones para la presentación individual

1. Cada estudiante realizará una **presentación oral individual** en video (10–12 minutos).
2. El tema será **"Fundamentos del Pentesting"**, abarcando:
    - Definición de pentesting.
    - Objetivos y alcances.
    - Principales fases (reconocimiento, escaneo, explotación, post-explotación, reporte).
    - Herramientas básicas.
    - Importancia ética y legal.
3. El material de apoyo (diapositivas o póster digital) debe:
    - Contener esquemas, gráficos o ejemplos claros.
    - Ser breve (no saturar texto).
    - Incluir fuentes de información confiables.
4. El estudiante debe hablar con claridad, seguridad y buena organización del tiempo.
5. Se evaluará tanto el **contenido** como la **forma de exposición**.

Evidencia:

Instituto Tecnológico Superior Progreso

Tarea:
Presentación individual acerca de los fundamentos del pentesting.

Fecha de entrega:
8 de septiembre de 2026

Asignatura:
Pentesting

Docente:
Martínez García Holzen Atocha

Alumno:
Valencia Hernández Carlos Eduardo

Carrera:
Ingeniería en sistemas computacionales

Semestre/Grupo:
Noveno/Grupo 1

Enlaces de Evidencia en Línea

Enlace al video de la presentación individual (SharePoint Institucional):
https://itprogreso-my.sharepoint.com/:v:/g/personal/l04220057_progreso_tecnm_mx/IQCJ2so49zF3S4T8m-wlsYxZAYJGFJF6XyJpHzw7mEO5Eno?e=dLuxYT

Enlace a la presentación interactiva en Canva Pro:
https://www.canva.com/d/yGDkFvV7g7el5Cf
(Vista previa directa: https://www.canva.com/d/HwH8bdltLLZ5Wp7)

Estructura Temática de Diapositivas y Guion Oral (11 min 30 s)

• Diapositiva 1: Portada y Presentación (0:00 - 0:40):
Bienvenida institucional, datos del expositor Carlos Eduardo Valencia Hernández y objetivo de la presentación.

• Diapositiva 2: ¿Qué es el Pentesting? (0:40 - 1:25):
Definición formal de prueba de penetración, simulación controlada y la autorización previa como frontera ética y legal.

• Diapositiva 3: Escaneo vs Auditoría vs Pentesting (1:25 - 2:15):
Diferencias críticas de enfoque: escaneo automatizado por firmas, auditoría documental de cumplimiento (ISO 27001) y pentesting analítico manual.

• Diapositiva 4: Objetivos Estratégicos (2:15 - 3:00):
Prevención de brechas, dimensionamiento del riesgo real en el negocio, validación de controles defensivos (Blue Team) y planes de remediación priorizados.

• Diapositiva 5: Alcance y Reglas de Compromiso (RoE) (3:00 - 3:45):
Delimitación de activos permitidos y prohibidos, horarios autorizados, salvaguardas operativas y prohibición de ataques DoS.

• Diapositiva 6: Tipos de Pruebas (3:45 - 4:30):
Modalidades de evaluación: Caja Negra (simulación de atacante externo anónimo), Caja Gris (usuario común o cliente) y Caja Blanca (acceso total a código y arquitectura).

• Diapositiva 7: El Ciclo de Vida del Pentesting (4:30 - 5:15):
Metodología estándar de 5 fases continuas: Reconocimiento, Escaneo, Explotación, Post-Explotación y Reporte formal.

• Diapositiva 8: Fases 1 y 2: Reconocimiento y Escaneo (5:15 - 6:05):
Inteligencia OSINT en fuentes abiertas, mapeo de puertos y servicios con Nmap y detección de vulnerabilidades conocidas (CVEs).

• Diapositiva 9: Fases 3 y 4: Explotación y Post-Explotación (6:05 - 7:00):
Validación práctica del exploit inicial, elevación de privilegios en el sistema objetivo, movimiento lateral y comprobación de persistencia.

• Diapositiva 10: Fase 5: Reporte Ejecutivo y Técnico (7:00 - 7:45):
Estructura del entregable: resumen ejecutivo en lenguaje financiero/negocio y reporte técnico detallado con PoC y parches para administradores.

• Diapositiva 11: Arsenal de Herramientas Básicas (7:45 - 8:35):
Nmap (redes), Wireshark (análisis de tráfico), Burp Suite (seguridad web), Metasploit Framework (explotación) y herramientas de contraseñas (John the Ripper / Hashcat).

• Diapositiva 12: Importancia Ética y Marco Legal (8:35 - 9:25):
El consentimiento informado por escrito, acuerdos de confidencialidad (NDA) y tipificación de delitos informáticos en el Código Penal Federal mexicano (Art. 211 bis).

• Diapositiva 13: Casos Reales y Lecciones de la Industria (9:25 - 10:10):
Análisis de incidentes: el caso Target (movimiento lateral por proveedor externo) y Capital One (mala configuración en AWS).

• Diapositiva 14: Conclusiones y Resiliencia (10:10 - 10:55):
Evolución de la defensa reactiva a la seguridad proactiva, cultura de mejora continua e integración en DevSecOps.

• Diapositiva 15: Referencias Confiables y Despedida (10:55 - 11:30):
Alineación a los estándares internacionales NIST SP 800-115, PTES, OWASP WSTG y Código Penal Federal.

3- Proyecto colaborativo: Plan básico de pentesting

Video - Entrevistas a empresarios.

Cierre: jueves, 10 de septiembre de 2026, 23:59

- **Objetivo de la tarea**: Elaborar un **video individual o en equipo de máximo 3 personas** (video de 5–8 minutos) en el que se presenten entrevistas a empresarios o responsables de TI sobre su percepción, experiencia y necesidades respecto al **Pentesting** y la **ciberseguridad**.
- **Pasos a seguir**:
  - **Diseño de preguntas**: Elaborar un guion breve con **5 a 8 preguntas relevantes**, por ejemplo:
    - ¿Qué tan importante considera la ciberseguridad en su empresa?
    - ¿Ha escuchado hablar del pentesting? ¿Cómo lo entiende?
    - ¿Ha aplicado alguna vez un servicio de pentesting o pruebas de seguridad?
    - ¿Qué beneficios o limitaciones percibe en su aplicación?
    - ¿Qué retos cree que enfrentan las empresas al implementar pruebas de seguridad?
  - **Selección de entrevistados**: Empresarios, gerentes de sistemas, encargados de TI, consultores o dueños de negocios locales.
  - **Grabación del video**:
    - Presentar brevemente el propósito de la entrevista.
    - Realizar las preguntas de manera clara.
    - Cuidar la calidad de audio e imagen (no es necesario ser profesional, pero sí entendible).
  - **Edición básica**: Agregar título inicial (nombre del proyecto) y créditos finales (participantes).
- **Entrega**:
  - Formato de video (MP4 HD recomendado)

Evidencia:

Instituto Tecnológico Superior Progreso

Tarea:

Proyecto colaborativo: Plan básico de pentesting.

Fecha de entrega:

14 de septiembre de 2026

Asignatura:

Pentesting

Docente:

Martínez García Holzen Atocha

Alumno(s):

Valencia Hernández Carlos Eduardo

Canul Canul Osvaldo

Carrera:

Ingeniería en sistemas computacionales

Semestre/Grupo:

Noveno/Grupo 1

1. Introducción

El presente documento técnico y metodológico tiene como propósito formalizar el diseño integral de un plan básico de prueba de penetración (pentesting) concebido específicamente para la organización "Farmacias del Mayab S.A. de C.V.", empresa de referencia en el sector farmacéutico y de distribución médica en el sureste de México, con sede central en Progreso y Mérida, Yucatán. La organización opera actualmente una red comercial de 45 sucursales físicas y ha consolidado una fuerte presencia digital a través de su plataforma omnicanal "MediMayab", la cual integra una aplicación web de comercio electrónico, un módulo de validación de recetas médicas electrónicas y una API REST que gestiona inventarios en tiempo real, cobros y facturación fiscal para miles de clientes. Ante el incremento del volumen transaccional y la digitalización de tratamientos médicos, la Dirección de Tecnologías de la Información de Farmacias del Mayab ha solicitado el diseño formal de este plan para evaluar de forma ordenada, ética y controlada la postura de seguridad de su infraestructura digital expuesta.

Es fundamental puntualizar que este instrumento no representa la ejecución material de los ciberataques, sino la etapa estratégica de planeación previa. En la disciplina de la seguridad ofensiva, la planeación formal constituye más del 70% del éxito de cualquier auditoría: realizar una prueba de penetración sin un alcance nítidamente acotado, sin reglas de compromiso estrictas, sin una delimitación temporal consensuada y sin roles autorizados transforma un ejercicio profesional en una actividad de alto riesgo operativo que puede desembocar en la caída no deseada de los servidores de venta, la corrupción de registros médicos o la incurrencia involuntaria en delitos informáticos conforme al marco normativo vigente.

En el contexto actual, la ciberseguridad se ha consolidado como un requisito vital para cualquier organización que gestione transacciones digitales y datos personales. Para Farmacias del Mayab, la materialización de un incidente de seguridad trasciende las pérdidas económicas inmediatas: implica el riesgo inminente de exfiltración de datos de salud altamente sensibles (diagnósticos clínicos y tratamientos farmacológicos), catalogados como datos especialmente protegidos por la Ley Federal de Protección de Datos Personales en Posesión de los Particulares (LFPDPPP) y la Norma Oficial Mexicana NOM-024-SSA3-2012, además del compromiso de información bancaria sujeta a rigurosas sanciones financieras y normativas bajo los estándares internacionales de PCI-DSS.

El pentesting se erige como la metodología más contundente para anticiparse a estos riesgos, permitiendo que la organización abandone la postura defensiva tradicional netamente reactiva —que suele depender de alarmas y registros posteriores al ataque— para adoptar una postura de resiliencia proactiva. Al simular metódicamente el comportamiento y las tácticas de un atacante real antes de que un cibercriminal explote las brechas existentes, la alta dirección podrá dimensionar con exactitud el impacto práctico de sus vulnerabilidades, priorizar las inversiones de corrección tecnológica y salvaguardar la confianza de sus pacientes en Yucatán.

2. Alcance del Pentesting

Objetivo general

Evaluar la postura de seguridad y el nivel de resiliencia de la infraestructura digital de Farmacias del Mayab S.A. de C.V. mediante la formulación y ejecución simulada de una prueba de penetración en modalidad de Caja Gris, fundamentada en la metodología OWASP Web Security Testing Guide (WSTG v4.2) y el OWASP API Security Top 10, con el propósito de identificar, validar y clasificar vulnerabilidades explotables que puedan comprometer la confidencialidad de los datos clínicos de los pacientes, la integridad de las transacciones financieras o la disponibilidad de la plataforma MediMayab.

Objetivos específicos

- **Identificar fallas de inyección:** Detectar inyecciones SQL, NoSQL y manipulación de comandos en parámetros de búsqueda del catálogo y filtros de existencias de medicamentos.
- **Auditar controles de acceso (BOLA y BFLA):** Verificar si usuarios de perfil cliente o cajero pueden alterar identificadores en la API para acceder a recetas médicas ajenas o funciones de administración.
- **Evaluar autenticación y sesiones:** Examinar la robustez de las sesiones basadas en JSON Web Tokens (JWT), resistencia a ataques de fuerza bruta y políticas de expiración de credenciales.
- **Verificar controles criptográficos:** Comprobar la configuración adecuada de TLS 1.3, algoritmos de cifrado simétrico y el resguardo de datos sensibles de tarjetas bancarias.
- **Auditar la subida de recetas médicas:** Validar que el módulo de carga de recetas impida la subida y ejecución de código malicioso (webshells) en el servidor de almacenamiento.
- **Revisar configuraciones del servidor:** Identificar cabeceras HTTP faltantes (HSTS, CSP), servicios expuestos innecesariamente y librerías desactualizadas con vulnerabilidades conocidas (CVEs).
- **Generar plan de remediación:** Entregar un reporte técnico y ejecutivo clasificado mediante CVSS v3.1 con recomendaciones prácticas para la corrección priorizada de los hallazgos.

Objetivos (Target URLs y Endpoints)

Las pruebas se concentrarán exclusivamente sobre los tres componentes centrales expuestos del cliente:

- **https://tienda.farmaciasdelmayab.com.mx:** Aplicación web principal para clientes finales. Incluye catálogo, carrito de compras, registro, login, pasarela de pago y carga de recetas médicas.
- **https://api.farmaciasdelmayab.com.mx/v2:** Interfaz de programación (API REST) que sirve como núcleo de datos para la tienda web, las terminales de punto de venta (POS) y la futura app móvil.
- **https://pos-web.farmaciasdelmayab.com.mx:** Portal web ligero para operadores de farmacia y cajeros de sucursal, empleado para consultar recetas y validar entregas locales.

Roles para probar

1. **Usuario no autenticado (Unauthenticated / Público):** Simula un atacante anónimo de internet sin credenciales que explora rutas públicas, catálogo y formularios de registro e inicio de sesión.
2. **Paciente / Cliente registrado (Standard Customer):** Simula a un cliente legítimo que realiza pedidos, consulta su historial, sube recetas médicas y administra sus tarjetas guardadas.
3. **Operador de Farmacia / Cajero de Sucursal (Branch Operator):** Simula a un empleado de sucursal con permisos para validar recetas, verificar existencias locales y autorizar despachos.
4. **Administrador de Sistemas (System Admin):** Perfil con privilegios elevados para configuración global, catálogo de precios, gestión de usuarios y generación de reportes financieros.

Áreas incluidas (In-Scope)

- **Módulos de autenticación:** Registro de usuarios, inicio de sesión, recuperación de contraseña, generación y validación de tokens JWT.
- **Comercio electrónico:** Gestión de carrito de compras, cálculo de promociones, aplicación de cupones y checkout.
- **Carga de documentos:** Mecanismos de validación de extensiones y tipos MIME en el módulo de recetas médicas.
- **Endpoints de la API REST v2:** Rutas CRUD de productos, recetas, inventarios, pedidos y perfiles de usuario.
- **Configuración de servidores web:** Servidor Nginx, políticas de CORS, cabeceras HTTP de seguridad y cookies.

Áreas excluidas (Out-of-Scope)

- **Infraestructura física:** Las 45 sucursales, almacenes, oficinas corporativas y centros de distribución.
- **Servicios de pasarelas de pago de terceros:** Servidores externos propiedad de proveedores bancarios (ej. Openpay, Stripe).
- **Consola de administración cloud:** Consolas de gestión de infraestructura de AWS/Azure que no pertenezcan al aplicativo.
- **Pruebas de ingeniería social:** Ataques de phishing, vishing o engaño dirigidos a los empleados o farmacéuticos.
- **Ataques de denegación de servicio (DoS/DDoS):** Queda prohibido saturar el ancho de banda o agotar la memoria de los servidores.
- **Modificación destructiva de datos de producción:** No se alterarán inventarios reales ni bases de datos de clientes reales.

Áreas de prueba según OWASP Top 10 y OWASP API Security Top 10

- **A01:2025 / API1:2023 – Broken Object Level Authorization (BOLA / IDOR):** Verificación de manipulación de IDs en endpoints `/api/v2/recetas/{id}` para consultar expedientes de terceros.
- **A02:2025 – Security Misconfiguration:** Detección de errores detallados, modo debug activo, cabeceras faltantes y puertos innecesarios.
- **A03:2025 / API3:2023 – Broken Object Property Level Authorization:** Validación de asignación masiva de campos protegidos (ej. modificar precios unitarios o roles en JSON).
- **A04:2025 – Cryptographic Failures:** Identificación de algoritmos criptográficos obsoletos y transmisión insegura de credenciales o tokens.
- **A05:2025 – Injection:** Inyecciones SQL en filtros de búsqueda del catálogo e inyección de comandos en rutinas de facturación.
- **A06:2025 – Insecure Design & File Upload Flaws:** Verificación de almacenamiento aislado y validación estricta al subir recetas médicas.
- **A07:2025 / API2:2023 – Broken Authentication:** Evaluación de ataques de fuerza bruta en logins, debilidad en firmas JWT y falta de expiración.
- **A08:2025 / API5:2023 – Broken Function Level Authorization (BFLA):** Comprobación de que clientes o cajeros no puedan invocar rutas administrativas de la API.
- **A09:2025 – Security Logging and Alerting Failures:** Revisión de registros de auditoría y generación de alertas ante múltiples accesos fallidos.
- **A10:2025 / API4:2023 – Lack of Rate Limiting:** Validación de mecanismos de límite de tasa para prevenir enumeración automatizada y abuso de cupones.

Arsenal de herramientas y justificación técnica

- **Burp Suite Professional:** Herramienta insignia para interceptación y manipulación de tráfico HTTP/S, escaneo activo y análisis de lógica de negocio.
- **Postman / Newman:** Plataforma de pruebas para APIs REST, automatización de payloads JSON y validación de Bearer tokens.

- **Nmap:** Mapeo de puertos, identificación de servicios de red y descubrimiento de versiones del servidor web.
- **SQLMap:** Detección y comprobación controlada de inyecciones SQL en parámetros vulnerables previamente localizados.
- **OWASP ZAP:** Escáner complementario para validación de alertas pasivas y activas en el entorno web.
- **ffuf (Fast Web Fuzzer):** Fuzzing de alto rendimiento para descubrimiento de rutas ocultas, archivos residuales y parámetros en la API.
- **jwt_tool:** Suite para auditoría de seguridad sobre tokens JSON Web Token, validación de firmas y manipulación de claims.
- **Browser DevTools:** Inspección de almacenamiento local, almacenamiento de sesión, atributos de cookies y cabeceras de respuesta.

3. Tipos de prueba

Análisis comparativo de los tres enfoques (Caja Negra, Blanca y Gris)

En la disciplina de las pruebas de penetración, la modalidad de evaluación se determina en función del volumen de información técnica previa y el grado de acceso que la empresa evaluada otorga al equipo auditor. Los estándares internacionales reconocen tres enfoques metodológicos:

- **Caja Negra (Black Box):** El equipo evaluador no recibe ninguna información técnica interna de la plataforma; únicamente se le suministran los dominios públicos. Simula el punto de vista de un atacante externo anónimo sin privilegios previos. Su fortaleza es el realismo operativo; no obstante, presenta una baja eficiencia en tiempo, ya que consume gran parte del presupuesto en recolección pasiva (OSINT) y escaneos a ciegas, limitando la profundidad del análisis de la lógica de negocio.
- **Caja Blanca (White Box):** El equipo evaluador cuenta con visibilidad y acceso absoluto: código fuente de la aplicación, diagramas de arquitectura de red, credenciales de administración y documentación de bases de datos. Ofrece una cobertura técnica exhaustiva; sin embargo, tiene un costo económico muy alto, requiere tiempos extensos y se aleja de la perspectiva real de un atacante del mundo exterior.
- **Caja Gris (Grey Box):** Es el esquema más eficiente y representativo en la industria. El cliente entrega información técnica parcial y relevante (documentación de endpoints de la API y credenciales de usuario con distintos niveles de privilegio), pero sin revelar el código fuente ni la red interna. Simula al usuario interno, al cliente malicioso o al atacante que ya ha obtenido una cuenta estándar y busca vulnerar los controles de autorización.

Modalidad	Información Otorgada	Perspectiva Simulada	Tiempo / Esfuerzo	Cobertura Técnica
Caja Negra	Nula (solo dominios públicos)	Atacante externo anónimo	Elevado en reconocimiento	Superficial / Perimetral
Caja Blanca	Total (código, red, admin)	Auditor interno / Desarrollador	Muy extenso y exhaustivo	Máxima / Integral

Caja Gris	Parcial (endpoints y cuentas)	Cliente o empleado malicioso	Optimizado y eficiente	Alta en lógica y control de acceso

Justificación de la selección: Caja Gris (Grey Box)

Para el proyecto de Farmacias del Mayab S.A. de C.V., el equipo evaluador ha determinado de manera fundada y técnica la selección de la modalidad de **Caja Gris (Grey Box)** como la más idónea y ventajosa, fundamentada en cuatro factores:

1. **Optimización del tiempo y costo de auditoría:** Evita malgastar días valiosos en recolectar información pública evidente y permite enfocar de inmediato el esfuerzo en las áreas críticas: pasarela de pago, validación de recetas y endpoints de la API.
2. **Simulación del vector de amenaza más peligroso:** Más del 85% de las brechas en plataformas e-commerce y de salud provienen de usuarios autenticados que intentan manipular peticiones para acceder a datos ajenos (fallas BOLA/IDOR). La caja gris permite evaluar este riesgo con rigor absoluto.
3. **Validación exhaustiva de la matriz de segregación de roles:** Al disponer de credenciales para rol Paciente y rol Cajero, se pueden ensayar intentos directos de escalada horizontal y vertical sin depender de adivinanzas.
4. **Protección de propiedad intelectual:** Farmacias del Mayab no se ve obligada a compartir sus repositorios de código fuente con consultores externos, resguardando el secreto de sus algoritmos comerciales.

4. Ventana de Usuario y Consideraciones Temporales

Concepto teórico de la ventana de usuario en ciberseguridad

En la gestión de proyectos de seguridad informática y auditoría ofensiva, la **ventana de usuario** (o ventana de pruebas / maintenance testing window) se define formalmente como el período horario específico, acordado y rubricado por ambas partes en el contrato de servicio, durante el cual se faculta al equipo evaluador para emitir tráfico ofensivo, escaneos e inyecciones sobre la infraestructura evaluada.

Su objetivo primordial consiste en salvaguardar la estabilidad operativa y comercial de la organización. Toda prueba de penetración genera un volumen anormal de peticiones con cargas útiles complejas que pueden sobrecargar bases de datos o disparar alarmas en los centros de monitoreo. La ventana de usuario delimita con exactitud cuándo los analistas pueden realizar pruebas intrusivas para no afectar a los clientes legítimos durante las horas pico de compras.

Aplicación y calendario operativo en Farmacias del Mayab

Con base en el análisis de tráfico transaccional de Farmacias del Mayab S.A. de C.V., el volumen de compra en línea y consulta de recetas desciende a sus niveles mínimos entre las 00:00 y las 05:00 horas. Por tanto, se establecen los siguientes bloques temporales:

- **Ventana de Pruebas Intrusivas y Automatizadas (00:00 a 05:00 horas):** De martes a viernes. En este bloque nocturno se autoriza el uso de herramientas automatizadas de fuzzing (ffuf), escaneo de vulnerabilidades (Burp Scanner, SQLMap) e inyecciones de payloads en endpoints de la API y formularios web.
- **Ventana de Validación Pasiva y Manual (05:00 a 07:00 horas):** Verificación puntual de hallazgos mediante navegación manual a bajo ritmo, comprobación de consistencia de la base de datos y revisión de que los servicios no presenten degradación antes del inicio de la jornada comercial.
- **Horario Comercial Diurno (07:00 a 23:59 horas):** Prohibición categórica de lanzar escaneos automatizados, pruebas de estrés o inyecciones masivas sobre los servidores productivos. Únicamente se permite análisis estático documental y redacción de reportes.

Política de Congelamiento de Cambios (Change Freeze)

Durante el período completo que abarquen las semanas de evaluación, la Dirección de TI de Farmacias del Mayab se compromete formalmente a establecer una política de **Congelamiento de Cambios (Change Freeze)** sobre la infraestructura de MediMayab. Esto implica que los desarrolladores internos y administradores de sistemas no realizarán nuevos despliegues de código (deploys), actualizaciones de parches en servidores ni modificaciones en las reglas del Web Application Firewall (WAF). Esta medida es vital para garantizar que los resultados obtenidos por los evaluadores sean reproducibles, consistentes y no se distorsionen por modificaciones intermedias en el software.

Canales de comunicación y contacto de emergencia

Para gestionar de forma ágil cualquier imprevisto técnico durante las ventanas nocturnas, se establece un canal de comunicación directo 24/7 mediante un grupo cifrado seguro (Microsoft Teams / Signal) y un enlace telefónico dedicado entre el Líder del Equipo de Pentesting y el Responsable de Monitoreo de Farmacias del Mayab. Si se detecta un incremento anómalo en el uso de CPU o la caída involuntaria de un microservicio, la comunicación inmediata permitirá aislar la causa en cuestión de minutos.

Plan de contingencia y marcha atrás (Rollback)

El equipo evaluador mantendrá un registro minucioso de cada cuenta, registro y archivo temporal creado durante las pruebas. Al término de cada sesión nocturna se ejecutará un procedimiento de limpieza y reversión (rollback) para eliminar carritos de prueba, recetas ficticias y desbloquear credenciales que hayan sido suspendidas por intentos fallidos de autenticación, garantizando que a las 07:00 horas el sistema opere en un estado 100% íntegro para el público general.

5. Roles y Responsabilidades

Estructura de gobernanza y actores del proyecto

Para que la prueba de penetración se desarrolle con total profesionalismo, rigor ético y validez jurídica, es imperativo definir con exactitud las atribuciones de cada uno de los actores involucrados en el proyecto:

1. **Cliente (Farmacias del Mayab S.A. de C.V.):** Actúa como la entidad contratante y propietaria de los activos digitales. Su Gerencia de Tecnologías de la Información funge como contraparte técnica operativa encargada de proveer el alcance autorizado, suministrar las credenciales de prueba para los roles y garantizar que las copias de seguridad de las bases de datos estén al día.
2. **Equipo de Pruebas (Pentesters de Ciberseguridad Ofensiva):** Grupo especializado encargado de la ejecución técnica de las pruebas siguiendo estrictamente el alcance y la metodología acordados. Sus responsabilidades comprenden la documentación detallada de cada hallazgo con evidencias reproducibles (PoC), el escalamiento inmediato ante riesgos críticos y la formulación del informe final de remediación.
   - **Líder del Proyecto y Pentester Principal (Valencia Hernández Carlos Eduardo):** Supervisa la conducción global del proyecto, actúa como canal de interlocución principal frente a la gerencia del cliente, coordina la ejecución de pruebas web en el portal de comercio electrónico y valida la calidad del informe final.
   - **Pentester Técnico y Especialista en APIs (Canul Canul Osvaldo):** Responsable de la auditoría técnica profunda sobre la API REST v2 (`/api/v2`), ejecución de pruebas de fuzzing, análisis de seguridad en tokens JWT, pruebas de autorización BOLA/BFLA y elaboración de las recomendaciones técnicas de mitigación.
3. **Responsables de Autorización (Sponsors Directivos y Legales):** Figura de máxima jerarquía corporativa en Farmacias del Mayab (Dirección General y Representante Legal, en coordinación con el Oficial de Seguridad CISO). Tiene la facultad legal indelegable de rubricar el contrato formal de servicios y la carta de consentimiento explícito ("Get Out of Jail Free letter"), amparando legalmente al equipo evaluador y actuando como máxima instancia de resolución ante cualquier contingencia.

Matriz RACI del proyecto de pentesting

A continuación se presenta la matriz de responsabilidades RACI (R = Responsable de ejecutar, A = Aprobador final, C = Consultado, I = Informado) para cada fase del proyecto:

Fase / Actividad del Proyecto	Líder Pentest (Carlos V.)	Pentester API (Osvaldo C.)	Gerente TI (Cliente)	Director / Sponsor
Definición de Alcance y RoE	**R**	C	**A**	**A**
Reconocimiento y Mapeo de APIs	**R**	**R**	I	I
Ejecución de Pruebas de Intrusión	**R**	**R**	C	I
Notificación de Hallazgos Críticos	**R**	**R**	**A**	I
Elaboración de Reportes Técnicos	**R**	**R**	C	I
Cierre y Presentación Ejecutiva	**R**	C	**A**	**A**

6. Reglas de Operación (RoE)

Las Reglas de Operación o Reglas de Compromiso (Rules of Engagement - RoE) constituyen el documento vinculante y de mayor trascendencia ética y legal en una prueba de penetración. Su propósito fundamental es delimitar las líneas rojas que el equipo evaluador no puede traspasar bajo ninguna circunstancia, garantizando que el ejercicio se desenvuelva con estricto apego al marco normativo de los Artículos 211 bis 1 al 7 del Código Penal Federal mexicano y preservando la continuidad de las operaciones de Farmacias del Mayab S.A. de C.V. A continuación se presentan las primeras cuatro reglas esenciales:

- **Regla 1: No afectación a la disponibilidad ni denegación de servicio (DoS/DDoS prohibido).** El equipo evaluador tiene estrictamente prohibido ejecutar ataques de denegación de servicio distribuido, inundaciones SYN/UDP o cualquier prueba de estrés orientada a colapsar los servidores web o de bases de datos. Si una herramienta automatizada comienza a elevar la latencia de respuesta por encima de 1500 ms, la prueba debe pausarse inmediatamente.
- **Regla 2: Confidencialidad absoluta y secreto profesional (Acuerdo NDA).** Toda la información recabada, credenciales de prueba, diagramas de arquitectura, datos de compras y vulnerabilidades detectadas durante la evaluación se considerarán secretos comerciales bajo un Acuerdo de No Divulgación (NDA). Queda terminantemente prohibida su transmisión a terceros o publicación pública sin autorización judicial o consentimiento por escrito del cliente.
- **Regla 3: Notificación inmediata de hallazgos críticos (<1 hora).** En el supuesto de que el equipo evaluador descubra una vulnerabilidad de severidad crítica (CVSS superior a 9.0) —tal como una ejecución remota de código (RCE), acceso no autenticado a la base de datos de pacientes o exposición directa de credenciales de la pasarela de pagos bancarios—, se suspenderá la explotación de dicho vector y se emitirá una alerta inmediata en menos de 60 minutos al CISO y Gerente de TI para su remediación urgente.
- **Regla 4: Prohibición estricta de exfiltración o modificación masiva de datos reales de clientes.** En caso de que una falla de autorización (BOLA/IDOR) o inyección SQL permita el acceso a tablas que contengan expedientes médicos o datos personales de clientes reales, los evaluadores se abstendrán

de descargar o almacenar copias de la base de datos. Como prueba de concepto (PoC), únicamente se documentará un único registro ofuscado o se utilizarán las cuentas de prueba creadas ex profeso.

Lineamientos y reglas de compromiso continuo

Complementando las directivas anteriores, se establecen las reglas de control técnico, trazabilidad y contención de emergencia que normarán las acciones operativas durante toda la auditoría:

- **Regla 5: Respeto irrestricto al alcance definido y áreas excluidas.** El equipo evaluador se compromete a no interactuar ni emitir tráfico contra dominios, servidores de correo electrónico o infraestructura no contemplados en la sección de alcance. Si durante el reconocimiento se descubren subdominios o paneles de sucursales no listados, se solicitará autorización formal por escrito antes de realizar cualquier escaneo.
- **Regla 6: Empleo exclusivo de credenciales y datos de prueba.** Las credenciales suministradas por el cliente para los roles de Paciente, Cajero y Administrador solo podrán emplearse para los fines de esta auditoría. Queda prohibido reutilizarlas en servicios externos o compartirlas fuera del equipo de dos pentesters formalmente acreditados.
- **Regla 7: Trazabilidad técnica obligatoria mediante IPs de origen fijas y cabeceras HTTP.** Todo el tráfico generado por el equipo evaluador provendrá exclusivamente de dos direcciones IP estáticas previamente registradas en el contrato. Asimismo, cada petición web y llamada a la API incluirá la cabecera HTTP personalizada `X-Pentest-Authorized: MediMayab-Audit-2026`, permitiendo al equipo de monitoreo del cliente auditar en tiempo real qué eventos corresponden a la auditoría legítima.
- **Regla 8: Protocolo de interrupción inmediata ("Botón Rojo").** Farmacias del Mayab se reserva el derecho unilateral de solicitar en cualquier instante la detención fulminante de las actividades mediante una orden telefónica o por mensaje al Líder del Pentest. Ante la activación del 'Botón Rojo', el equipo suspenderá todos los scripts y procesos en un tiempo máximo de tres minutos, procediendo a una sesión de evaluación conjunta.

El estricto cumplimiento de estas ocho reglas asegura que la prueba de penetración se lleve a cabo como un ejercicio de ingeniería de software altamente profesional, protegiendo a la empresa contra cualquier degradación de sus servicios y amparando al equipo evaluador bajo un marco ético indiscutible.

7. Conclusiones y Reflexiones del Equipo

Valencia Hernández Carlos Eduardo

Al desarrollar este plan básico de pentesting para Farmacias del Mayab S.A. de C.V., pude comprender que la seguridad ofensiva profesional dista enormemente de la concepción popular de ejecutar herramientas automatizadas para vulnerar sistemas. Mi aprendizaje más significativo radicó en entender que la planeación estratégica y la delimitación del alcance son los pilares fundamentales que otorgan validez técnica y protección legal al evaluador. Antes de esta práctica, solía percibir las auditorías como desafíos puramente técnicos; sin embargo, al redactar los objetivos generales, específicos y las áreas excluidas, descubrí que una mala definición del alcance puede poner en riesgo la viabilidad operativa de una empresa y acarrear graves responsabilidades legales conforme al Código Penal Federal mexicano.

Asimismo, el diseño de la estructura de roles y responsabilidades me demostró que el líder de un proyecto de ciberseguridad debe poseer sólidas habilidades de comunicación gerencial y pensamiento preventivo: saber cómo coordinar ventanas de bajo tráfico, consensuar canales de contingencia y garantizar que un ejercicio de intrusión no interfiera con las ventas de una cadena farmacéutica es tan crítico como saber explotar una falla de inyección. Esta experiencia consolidó mi visión de que el pentester moderno debe ser un aliado estratégico del negocio que ayuda a blindar los activos de información más sensibles.

Canul Canul Osvaldo

Mi principal contribución y aprendizaje a lo largo de este proyecto colaborativo se centró en el análisis de los tipos de prueba y la estructuración técnica de las áreas bajo el marco OWASP Top 10 y OWASP API Security. Al profundizar en las diferencias entre caja negra, caja blanca y caja gris, comprendí con claridad por qué la caja gris es el estándar más eficiente y demandado en la industria: en plataformas omnicanal modernas con múltiples perfiles (como pacientes, cajeros y administradores), las vulnerabilidades más críticas no suelen ser fallas perimetrales evidentes, sino debilidades en la lógica de autorización a nivel de objeto (BOLA/IDOR) y a nivel de función (BFLA). Poder contar con credenciales parciales para validar si un usuario puede acceder a recetas médicas ajenas aporta un valor incalculable que no se logra con una caja negra.

Por otra parte, el desarrollo de las Reglas de Operación (RoE) y la ventana de usuario me permitió asimilar que el hacking ético requiere una disciplina metodológica inflexible. Establecer mecanismos de trazabilidad como el uso de cabeceras HTTP personalizadas y definir un protocolo de parada de emergencia ('Botón Rojo') son elementos indispensables para diferenciar una auditoría profesional de una intromisión negligente. Este ejercicio me brindó un panorama integral de cómo conectar los conceptos teóricos vistos en clase con las exigencias reales y normativas de una empresa que maneja datos de salud en el sureste mexicano.

8. Referencias

1. Cámara de Diputados del H. Congreso de la Unión. (2021). Código Penal Federal: Título Noveno - Delitos contra la indemnidad de privacidad y la información (Artículos 211 bis 1 al 211 bis 7). Diario Oficial de la Federación. https://www.diputados.gob.mx/LeyesBiblio/pdf/CPF.pdf
2. Instituto Nacional de Ciberseguridad (INCIBE). (2022). Guía de aproximación a las pruebas de penetración y seguridad ofensiva para empresas y organizaciones. INCIBE-CERT. https://www.incibe.es/guia-pentesting
3. Instituto Nacional de Transparencia, Acceso a la Información y Protección de Datos Personales (INAI). (2020). Guía para el tratamiento seguro de datos personales en aplicaciones web y servicios digitales en el sector salud. INAI. https://home.inai.org.mx/
4. OWASP Foundation. (2023). Guía de pruebas de seguridad para aplicaciones web (WSTG v4.2 en español) y Top 10 de riesgos en seguridad de APIs. Open Web Application Security Project. https://owasp.org/www-project-web-security-testing-guide/
5. Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2018). Guía técnica para pruebas y evaluaciones de seguridad de la información (Traducción y adaptación al español del estándar NIST Special Publication 800-115). National Institute of Standards and Technology / Departamento de Comercio de los Estados Unidos. https://doi.org/10.6028/NIST.SP.800-115



Coevaluación final (parcial 1)

Formato para Co-evaluación

Tomando como referencia el desempeño de tus compañeros de grupo, se pide realizar una evaluación de cada integrante tomando como referencia la siguiente escala de calificación.

Nunca 0	Ocasionalmente 2	Frecuentemente 4	Siempre 6

COMPETENCIA	Puntuación por Integrante					
	Erick Espinosa	Osvaldo Canul	Lopez Acosta	Coba Cuevas		Promedio
Respeta las ideas de los otros miembros del grupo.	6	6	6	6		6
Desempeña un papel activo en la búsqueda de información relevante y la comparte con el grupo.	6	6	6	6		6
Comparte la información que encuentra con los otros miembros del grupo.	6	6	6	6		6
Presenta sus ideas de una manera coherente.	6	6	6	6		6
Su desempeño en el rol asignado ha contribuido a cumplir con las tareas.	6	6	6	6		6
Su participación permite el desarrollo de óptimas relaciones interpersonales.	6	6	6	6		6
Es puntual a las reuniones para desarrollar las actividades realizadas.	6	6	6	6		6
Es capaz de reconocer y enmendar sus errores.	6	6	6	6		6
					Puntuación Total	48



Autoevaluación final (parcial 1)

Formato para autoevaluación

Tomando como referencia tu desempeño en el salón de clases, se pide realizar una autoevaluación tomando como referencia la siguiente escala de calificación.

Nunca 0	Ocasionalmente 2	Frecuentemente 4	Siempre 6

COMPETENCIA	Autoevaluación			
	Nunca	Ocasionalmente	Frecuentemente	Siempre
Respeto las ideas de los otros integrantes del salón de clases.				6
Desempeño un papel activo en la búsqueda de información relevante y la comparto con el grupo.				6
Soy puntual a las reuniones para desarrollar las actividades encomendadas.			4	
Soy capaz de reconocer y enmendar mis errores.				6
Llego con puntualidad a las clases.			4	
Participo de manera activa con preguntas o comentarios en la clase.				6
		Puntuación Total	32	

Experiencias de aprendizaje y comentarios finales (parcial 1)

Experiencia de aprendizaje

En esta primera unidad de la asignatura de Pentesting aprendimos los fundamentos teóricos, metodológicos y legales de la seguridad ofensiva. Estudiamos las diferencias sustanciales entre el escaneo de vulnerabilidades, las auditorías normativas y las pruebas de penetración reales; exploramos la evolución histórica de la disciplina desde los primeros tiger teams hasta las metodologías contemporáneas como PTES, NIST SP 800-115 y OWASP; y adquirimos la destreza de diseñar un plan básico de pentesting estructurado en modalidad de caja gris para un caso real del sector farmacéutico, estableciendo rigurosas reglas de compromiso (RoE) y ventanas de usuario.

Comentarios finales

Fue una excelente unidad introductoria que transformó por completo mi entendimiento de la ciberseguridad, pasando de una perspectiva meramente pasiva y reactiva hacia un enfoque ofensivo proactivo y ético. Comprender que una auditoría exitosa depende en un 80% de la planeación estratégica, de la adecuada delimitación de alcances y del marco jurídico del Código Penal Federal me brinda bases sólidas e invaluables para mi futuro desempeño profesional en ingeniería.